

Take-Home Assignment: Independent Vulnerability Assessment

Capstone — Applying Labs 1-4 Without a Walkthrough

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion assignment **Format:** Individual, completed outside class, in your own lab environment **Estimated time:** 2-3 hours **Prerequisite:** Labs 1-4 completed. You should be comfortable running Nmap, using `msfconsole`'s `search` / `check` / `exploit` sequence, and cracking hashes with John. **Due:** (instructor to fill in)

Before You Start — This Time, Nobody Checks Your Adapter Settings

Every guided lab so far had an instructor in the room. This one doesn't. Before you touch anything tonight:

1. Confirm your Kali VM's Adapter 1 is still **Host-only**, and Adapters 2-4 are still **Disabled**. Working from home does not change the rule — it makes it more important, because nobody is walking the room to catch a mistake.
2. Everything in this assignment targets **your own Metasploitable 2 and OWASP BWA VMs on your own host-only network**, and nothing else. Do not point anything below at your home router, your ISP's network, or any system you do not personally own — that instantly falls outside the Four Gates, homework or not.
3. Restore both targets to their `baseline-pre-attack` snapshot before you begin, so you're starting from the same known-clean state as Lab 1.

What's Different About This Assignment

Labs 1-4 told you which command to run. This assignment tells you which *question* to answer, and leaves the command up to you — the same gap between a guided lab and an actual engagement. Expect to spend real time in `-help` output, module `info` pages, and your own notes from Labs 1-4.

Learning Objectives

By submitting this assignment you will have:

- Run a broader scan than any single lab required, and triaged the results yourself
 - Located and evaluated an exploit for a service **other than** the vsftpd backdoor from Lab 3, without being told its name
 - Decided, and defended in writing, whether exploitation succeeded, failed, or wasn't worth attempting
 - Produced a two-part deliverable that separates breadth (a vulnerability assessment) from depth (a penetration test) — the same distinction the module draws between engagement types
-

Part 1 — Breadth: Build a Real Findings Table

Lab 2 scanned a handful of ports. This time, scan all of them.

1. Run a full-range, version-detecting scan against Metasploitable 2:

```
nmap -sV -O -p- 192.168.56.102
```

This takes longer than Lab 2's scan — that's expected.

2. From the results, build a findings table with **at least five services you have not already exploited in Lab 3**. For each row, record:
 - Port / protocol
 - Service and version string
 - Your own rough severity call — Critical / High / Medium / Low — with one sentence justifying it (you do not need a formal CVSS score; state your reasoning)
3. Sort the table by severity, highest first. This is the "breadth over depth" deliverable the module describes for a vulnerability assessment — you are cataloguing, not yet exploiting.

Part 2 — Depth: Pick One Finding and Go After It

1. From your Part 1 table, choose **one** service — not FTP/vsftpd — to actually test.
2. Find out whether it's exploitable. You have two starting points; use whichever gets you there:
 - Inside `msfconsole`: `search <service or product name>`, then `info` on anything promising
 - From a terminal: `searchsploit <service or product name>`
3. If you find a plausible module: set it up the same way you did in Lab 3 — `set RHOSTS`, `check` if it's supported, then `exploit` — and confirm what access you get (`id`, `whoami`).
4. If nothing pans out after a genuine attempt: that's a valid outcome. Document what you tried, what you ruled out, and why. A professional report that says "assessed, not exploitable with available tooling" is worth real points here — guessing and leaving no record is not.
5. Whatever happens, keep a log the whole time (`spool`, same as Lab 3), and screenshot or copy the key output.

Part 3 — If You Got In: One Step Further

If Part 2 got you a shell, do **one** of the following (your choice) before you stop:

- **Repeat Lab 4's password audit** against this new host access, if the account has read access to hash-worthy files
- **Search the filesystem** for one piece of data an attacker would actually care about — a config file with embedded credentials, a note, a database dump — and record where you found it and why it matters. Don't exfiltrate anything beyond noting its location and content in your log; this is still Phase 3, not Phase 4.

If Part 2 didn't get you in, skip Part 3 and say so in your report — don't force a result.

Part 4 — Write It Up

Produce a single report with two sections, addressed to Metasploitable's system administrator:

Section A — Vulnerability Assessment. Your Part 1 table, formatted the way slide 6's sample report was: port, evidence, severity, and a one-line fix for every row, not just the one you exploited.

Section B — Penetration Test Finding. One full write-up for your Part 2/3 work: what you found, what you proved you could do with it, the exact evidence (log excerpt or command output), and the fix. If Part 2 failed, this section instead documents the attempt and your reasoning for why it didn't succeed.

Reflection — Answer All Four

1. Which of the module's three engagement types — vulnerability assessment, penetration test, or security test — does this assignment actually resemble? Defend your answer; more than one answer can be defended if you argue it well.
2. Walk through the Four Gates specifically for tonight's homework: what stands in for written permission, scope, permitted technique, and time window when the "client" is your own syllabus?
3. Suppose you'd found this exact vulnerability on a live company network, with no authorization, while poking around out of curiosity. Name the statute that would apply, and state in one sentence what actually separates that scenario from tonight's assignment.
4. Compare how long you spent *finding* the vulnerability against how long you spent *exploiting* it once found. Does your own experience support or contradict the module's claim that the real skill is in scoping and reporting, not running the tool?

Submission Checklist

- ☐ Part 1 findings table (5+ services, severity, justification)
- ☐ Part 2 log/spool file or documented failed attempt
- ☐ Part 3 output (password audit results or filesystem finding) — or a note that Part 2 didn't succeed
- ☐ Part 4 two-section report
- ☐ All four reflection answers
- ☐ One line confirming both target VMs were restored to `baseline-pre-attack` when you finished

Submit as a single PDF. Redact any actual password values you recovered — report that a credential was cracked, not the credential itself, same rule as Lab 4.

A Few Hints, Not the Answer

- Kali's own menu groups tools by phase — Information Gathering, Vulnerability Analysis, Exploitation Tools. If you're stuck on where to look next, that grouping is the syllabus, same as slide 15 pointed out.

- `searchsploit` searches a local, offline exploit database — faster than `msfconsole`'s `search` for a first pass, and it works even if your Metasploit module cache is out of date.
- Not every open port on this box has a one-command exploit. Ruling a service out with a documented reason is a legitimate finding — some of the best answers to this assignment include at least one “I checked, and here’s why it wasn’t worth pursuing further.”

Grading (suggested — adjust to your rubric)

Component	Weight
Part 1 — Findings table (breadth, accuracy, severity reasoning)	25%
Part 2 — Independent exploitation attempt (method, not just outcome)	30%
Part 3 — Post-exploitation step (or valid skip if Part 2 failed)	10%
Part 4 — Report quality (clarity, evidence, actionable fixes)	20%
Reflection answers	15%

A student who tries a reasonable module, fails, documents it honestly, and writes a clean report can score as well as one who happens to get a shell on the first try. This assignment grades the process, not the exploit.

Academic Integrity

Your log output and screenshots should show your own VM’s hostname/prompt. Comparing notes with classmates about *which service* you chose is fine — submitting identical exploitation logs is not.

This assignment is the last Module 1 deliverable. Come to the Module 2 session with both VMs restored and this report submitted.